

A Secure Hybrid Post-Quantum Cryptographic Key Exchange for ESP32 IoT Devices

Muhammad Sohaim Muqtada

Department of Cybersecurity

University of Management and Technology (UMT)

Lahore, Pakistan

f2024408084@umt.edu.pk

Abstract—IoT edge nodes deployed in industrial, medical, and municipal networks increasingly rely on Elliptic Curve Diffie-Hellman (ECDH) for session key establishment. Once a Cryptographically Relevant Quantum Computer (CRQC) becomes operational, Shor’s algorithm renders every such session retroactively decryptable—a threat compounded today by Harvest Now, Decrypt Later (HNDL) adversaries who archive encrypted traffic for future decryption. This paper reports our hands-on implementation of a stateful hybrid key-exchange protocol on a physical Espressif ESP32-D0WD-V3 microcontroller running FreeRTOS. The protocol runs X25519 and ML-KEM-768 (NIST FIPS 203) in parallel, binding both shared secrets through HKDF-SHA256 so that session confidentiality survives even if one primitive is broken. Mutual authentication is enforced using HMAC-SHA256 authentication tags keyed by a 32-byte pre-shared key; subsequent telemetry packets are encrypted with AES-256-GCM and protected against replay via a monotonic sequence counter in the GCM IV. Over 100 measured iterations on the real board, we recorded a mean handshake latency of 635.88 ms, a peak SRAM heap consumption of 13.8 KB, and a total CPU cost of 103.38M cycles. Energy boundaries were physically established using a UNI-T UTP1310 laboratory power supply (5.00V) and a UNI-T UT55 digital multimeter across a 0.1 Ω shunt resistor, confirming an upper bound of 0.75 J per handshake at a 150 mA peak, safely below the onboard regulator’s brownout threshold. To validate long-term operational resilience, physical endurance testing captured 17,502 raw TCP SYNs on the wire and logged 14,157 completed sessions across 19.00 cumulative active hours in 4 operational sittings, with an 8.10-hour longest continuous window. Finally, the protocol state machine and key agreement were formally verified using the ProVerif automated theorem prover, mathematically confirming session key secrecy against active Dolev-Yao adversaries and eliminating responder replay vulnerabilities via strict transcript binding.

Index Terms—Post-Quantum Cryptography, Internet of Things, Embedded Systems, Hybrid Key Exchange, ESP32, ML-KEM, Curve25519, FreeRTOS.

I. INTRODUCTION

When we started this project, the central question was simple: can a 240 MHz dual-core microcontroller with 520 KB of SRAM run both X25519 and ML-KEM-768 in a single handshake without crashing the FreeRTOS watchdog, starving the Wi-Fi stack, or running out of heap? The answer turned out to be yes — but getting there required solving three concrete engineering problems that existing literature does not address head-on.

ESP32 nodes are common in real deployments—industrial sensor grids, smart-metering infrastructure, hospital telemetry

endpoints—because they combine Wi-Fi, Bluetooth, and dual-core processing in a sub-\$5 package. Their sessions today rely on X25519 ECDH [5], which provides strong 128-bit classical security. That guarantee disappears entirely once a fault-tolerant quantum computer running Shor’s algorithm [1] becomes available, reducing X25519’s security parameter to zero. The HNDL threat makes the deadline earlier than it appears: adversaries are already collecting ciphertext today, waiting to decrypt it later. For sensor nodes protecting long-lived data—municipal water control SCADA logs, medical device readings, power-grid telemetry—the exposure window already exceeds plausible CRQC deployment timelines [10].

NIST finalized the answer in August 2024 with FIPS 203 [2]: ML-KEM, derived from CRYSTALS-Kyber, is now the primary standardized Key-Encapsulation Mechanism. ML-KEM-768 targets NIST Security Category 3, grounded in the decisional Module Learning With Errors (M-LWE) hardness problem over the ring $R_q = \mathbb{Z}_q[X]/(X^{256} + 1)$ with modulus $q = 3329$ [27]. We did not simply swap out X25519 for ML-KEM-768, however. Running both in parallel — the hybrid approach — is explicitly recommended by NIST [9]: if an unexpected algebraic break in lattice arithmetic surfaces, the classical X25519 component preserves security. The reverse is equally true.

Our implementation negotiates the ephemeral cryptographic key exchange in a single application-layer round-trip (one HTTP request/response flight) over an established TCP transport, completely eliminating the multi-flight handshakes and X.509 certificate parsing overhead of TLS 1.3. We ran it on a physical board, measured it with hardware timers, and verified its electrical behaviour with a bench supply. The full source, raw serial logs, and captured network traces are published at the repository listed in the Data Availability section.

A. Contributions

Prior work has run post-quantum and hybrid KEMs on the ESP32 [11], [19], [23], [25], [26], but typically as standalone benchmark kernels rather than integrated, network-connected, mutually-authenticated protocols with live telemetry. Our specific contributions are:

- 1) A native, non-TLS RTOS handshake that bypasses X.509 certificate parsing entirely, fitting the combined X25519 and ML-KEM-768 state into 13.8 KB of dynamic heap — verified on real hardware.

- 2) An engineering fix for FreeRTOS TWDT starvation caused by ML-KEM-768's NTT butterfly loops, using loop-boundary watchdog feeds outside the cryptographic routines so constant-time execution is preserved.
- 3) Empirical power profiling from a UNI-T UTP1310 laboratory power supply injected directly onto the VIN pin (bypassing the USB regulator), producing the 30–70 mA fluctuating load curve reported in Table VII.
- 4) A mutual authentication and key-rotation scheme that ties HMAC-SHA256 PSK authentication to the handshake and automatically rotates AES-256-GCM session keys every 50 telemetry packets.

II. RELATED WORK

A. Lattice-Based Cryptography: From Theory to Embedded Practice

The path from Regev's original LWE construction [3] to a running firmware binary on an Xtensa microcontroller is not obvious, and the literature reflects that. Early LWE schemes were unworkably large — key sizes scale quadratically with security parameter n . Ring-LWE changed that by moving operations into polynomial rings, where the Number Theoretic Transform (NTT) drops multiplication from $O(n^2)$ schoolbook to $O(n \log n)$ [13], [15], [30]. Module-LWE goes one step further: it parameterizes security via a module rank k over a fixed-degree ring, giving a single codebase that scales across security levels. That is what lets ML-KEM-768, ML-KEM-768, and ML-KEM-1024 share their core NTT implementation — an important practical point for code-size-constrained firmware [28].

B. Hybrid Key Encapsulation

The case for running two KEMs simultaneously rather than picking one is theoretically grounded: Bindel et al. [8] formally proved that a combiner KEM is secure as long as at least one constituent KEM is secure. NIST SP 800-227 [9] and the ongoing IETF drafts [16], [17] both recommend hybrid designs for exactly this reason during the transition period. Our implementation directly applies this combiner pattern.

C. TLS vs. Bare-Metal RTOS Approaches

Most hybrid PQC integration work targets TLS 1.3 [14], [16], [17]. The advantage is clear: you get a fully standardized, analyzed protocol. The cost on constrained hardware is also clear: in our own measurement, a standard mbedTLS 1.3 handshake with an ECDHE-ECDSA certificate consumes 776.40 ms and 372.66M CPU cycles on the same ESP32 board, and its peak dynamic allocation exceeds 49 KB — leaving insufficient SRAM headroom for ML-KEM-768's 1,184-byte public key and 2,400-byte secret key on top. We therefore eliminated the complex TLS state machine entirely and structured the cryptographic negotiation as a single application-layer round-trip (1 RTT) directly over an established TCP connection. This architectural decision strictly decouples transport setup (the standard TCP 3-way handshake) from the ephemeral key agreement (one

ClientHello/ServerHello exchange) and subsequent authenticated telemetry flights, which is the key design choice that makes fitting into a 13.8 KB dynamic memory bound possible.

D. PQC Benchmarks on Constrained Processors

The pqm4 project [7] established the ARM Cortex-M4 as the standard embedded PQC benchmark target. Botros et al. [6] and Abdulrahman et al. [12] squeezed fast Kyber implementations into tight SRAM using hand-written NTT assembly. Our target, the Xtensa LX6, is a different architecture — it lacks the Cortex-M4's SIMD MAC instructions — so those optimizations do not transfer directly [11], [23]. We measured the performance overhead of this architectural gap and report it in our benchmarks.

E. IoT Security and the HNDL Threat

Mosca's formal framing of the HNDL risk [10] is the clearest articulation of why the upgrade timeline for long-lived sensor nodes is urgent. Lightweight cryptography work and mbedTLS/wolfSSL integrations [20], [21] have addressed classical threats, but FreeRTOS-specific failure modes during heavy polynomial arithmetic — the watchdog starvation we encountered on Core 1 — are not discussed in any of these references. We document and solve that failure mode here.

III. CRYPTOGRAPHIC PRELIMINARIES AND HYBRID KEY AGREEMENT

A. Mathematical Foundations of Curve25519

X25519 is the ECDH function built on Curve25519, a Montgomery curve over $\mathbb{F}_p$ where $p = 2^{255} - 19$. The curve equation is:

$$E_{A,B} : By^2 = x^3 + Ax^2 + x \pmod{p} \quad (1)$$

with $A = 486662$, $B = 1$ [5]. The protocol works only on x -coordinates, which is what makes the Montgomery ladder efficient and branchless. Our ESP32 client generates a random 32-byte private scalar d_C , clamps it to clear the cofactor bits:

$$d'_C = 2^{254} + 8 \cdot \left\lfloor \frac{d_C \bmod 2^{254}}{8} \right\rfloor \quad (2)$$

then computes $Q_C = x([d'_C]P_B)$ where the base point has $x_P = 9$. After receiving the server's Q_S , the shared secret is:

$$\text{X25519_ss} = x([d'_C]Q_S) \in \mathbb{F}_p \quad (3)$$

B. Module Learning With Errors and ML-KEM-768

ML-KEM-768 works in the ring $R_q = \mathbb{Z}_q[X]/(X^{256} + 1)$ with $q = 3329$ and module dimension $k = 3$ [2]. Security rests on the M-LWE problem: given a public pair (A, t) where

$$t = As + e \pmod{q} \quad (4)$$

with small secret $s \in R_q^k$ and noise $e \in R_q^k$ drawn from centered binomial distribution B_η ($\eta_1 = \eta_2 = 2$), distinguish (A, t) from uniform random. This is believed hard for both classical and quantum computers, targeting NIST Security Category 3 (192-bit security level).

1) *Number Theoretic Transform (NTT)*: Because $q = 3329 \equiv 1 \pmod{256}$, there exists a primitive 256th root of unity $\zeta = 17 \pmod{q}$. This is what makes the NTT work. The Cooley-Tukey butterfly at each stage is:

$$u \leftarrow X_j, \quad t \leftarrow \zeta^W X_k \pmod{q} \quad (5)$$

$$X_j \leftarrow u + t \pmod{q}, \quad X_k \leftarrow u - t \pmod{q} \quad (6)$$

where W follows the bit-reversal permutation. This reduces polynomial multiplication from $O(n^2)$ to $O(n \log n)$ — on a 240 MHz Xtensa this is the difference between a starvation-triggering delay and a manageable one. For modular reduction, we use Barrett reduction with constant $\mu = \lfloor 2^{32}/q \rfloor = 1290167$:

$$\text{Reduce}(a) = a - \lfloor \frac{a \cdot \mu}{2^{32}} \rfloor \cdot q \quad (7)$$

and Montgomery reduction for multiplications, where $\beta = 2^{16}$ and $q' = 3327$ (since $q \cdot q' \equiv -1 \pmod{\beta}$):

$$\text{MontReduce}(a) = \lfloor \frac{a + (a \cdot q' \bmod \beta) \cdot q}{\beta} \rfloor \quad (8)$$

Outputs are then conditionally subtracted to normalize into $[0, q - 1]$.

2) *Fujisaki-Okamoto Transform*: ML-KEM achieves IND-CCA2 security by wrapping an IND-CPA public-key encryption scheme with the Fujisaki-Okamoto (FO) transform [4]. In concrete terms:

- **Encapsulate**: The caller uses public key $pk = (t, \rho)$ to produce ciphertext $c = (c_1, c_2)$ and the 256-bit shared secret ML-KEM_ss.
- **Decapsulate**: The holder of secret key $sk = (s, pk, H(pk), z)$ decrypts by computing $m' = c_2 - s^T c_1 \pmod{q}$, applies polynomial error correction, and confirms correctness by re-encrypting. On mismatch it returns a deterministic pseudorandom output, preventing the oracle queries that IND-CPA schemes are vulnerable to.

C. Cryptographic Key Binding via HKDF

Binding the classical and post-quantum shared secrets is necessary to prevent an adversary from tampering with either component. We use HKDF-SHA256 [9] in two steps:

- 1) **Extract Step**: We extract a single pseudorandom key (PRK) from the concatenated secrets. The extraction uses the transcript hash $\text{transcript_hash} = \text{SHA256}(\text{ClientHello} \parallel \text{ServerHello})$ as the salt:

$$\text{PRK} = \text{HMAC-SHA256}(\text{transcript_hash}, \text{X25519_ss} \parallel \text{ML-KEM_ss}) \quad (9)$$

- 2) **Expand Step**: We expand the PRK into the final 256-bit session key by prepending the transcript hash to the info string:

$$\begin{aligned} \text{session_key} = & \text{HMAC-SHA256}(\text{PRK}, \\ & \text{transcript_hash} \parallel \text{"session-key"} \\ & \parallel 0x01) \end{aligned} \quad (10)$$

IV. HYBRID PROTOCOL SPECIFICATION AND MESSAGE LAYOUT

The protocol operates over a persistent TCP transport. Transport connection establishment follows the standard TCP 3-way handshake (1 transport RTT via $\text{SYN} \rightarrow \text{SYN-ACK} \rightarrow \text{ACK}$). Once the TCP transport is active, the core cryptographic key-exchange phase executes in exactly a single application-layer round-trip (1 application RTT): the ESP32 client transmits its 1,249-byte `ClientHello` containing ephemeral public keys and HMAC tag, and receives the 1,168-byte `ServerHello` containing the server's public key, ML-KEM ciphertext, and `ServerFinished` MAC. Both endpoints derive the bound 256-bit session key, after which key confirmation and subsequent authenticated telemetry flights proceed over the same persistent TCP connection.

We chose HTTP/1.1 as the application framing layer deliberately for this research prototype because it keeps the Python server simple and lets us capture clean Wireshark traces without TLS record-layer wrapping. The binary cryptographic payloads are transport-agnostic; they could equally sit inside MQTT or CoAP messages in a production deployment. Authentication uses HMAC-SHA256 under a 32-byte PSK compiled as a firmware constant. In production, this PSK would be injected during board programming into the ESP32's eFuse or NVS partition under Secure Boot V2.

This work is not proposing that HTTP/1.1 replace TLS for general Internet deployments. The contribution is a compact, memory-fitting hybrid handshake kernel for pre-provisioned IoT nodes where certificate stores and full TLS stacks are impractical.

A. Handshake Request (*ClientHello*) Layout

The client serializes its public key material:

$$\text{ClientHello} = \text{Mode} \parallel Q_C \parallel pk_{\text{KEM}} \quad (11)$$

The payload consists of a 1-byte mode identifier (Hybrid = 2), a 32-byte X25519 public key, an 1,184-byte ML-KEM-768 public key, and a 32-byte HMAC-SHA256 authentication tag, totalling 1,249 bytes.

B. Handshake Response (*ServerHello*) Layout

The server response body encodes a 16-byte session identifier, cryptographic response, and a 32-byte MAC-based key confirmation message (`ServerFinished`):

$$\begin{aligned} \text{ServerHello} = & \text{SID} \parallel Q_S \parallel c_{\text{KEM}} \\ \text{ServerFinished} = & \text{HMAC-SHA256}(\text{session_key}, \\ & \text{transcript_hash}) \\ M_{\text{resp}} = & \text{ServerHello} \parallel \text{ServerFinished} \end{aligned} \quad (12)$$

The payload consists of a 16-byte Session ID, a 32-byte X25519 public key, a 1,088-byte ML-KEM-768 ciphertext, and a 32-byte `ServerFinished` MAC, totalling 1,168 bytes.

C. Client Key Confirmation Layout

To finalize the handshake and prove possession of the derived keys, the client sends a `ClientFinished` message to the `/handshake_finished` endpoint. This is constructed as a MAC over the transcript hash:

$$\text{ClientFinished} = \text{HMAC-SHA256}(\text{session_key}, \text{transcript_hash} \parallel 0x02) \quad (13)$$

D. Telemetry POST Body Layout

Each encrypted telemetry packet is structured as:

$$P_{\text{telem}} = \text{SID} \parallel \text{IV} \parallel C \parallel \tau \quad (14)$$

The payload consists of a 16-byte Session ID, a 12-byte GCM IV, a variable-length ciphertext C , and a 16-byte GCM Authentication Tag τ .

The overall system architecture is illustrated in Fig. 1, detailing the dual-core pinning and network stack isolation. The hybrid handshake message exchange sequence is shown in Fig. 2.



Fig. 1. System Architecture Diagram

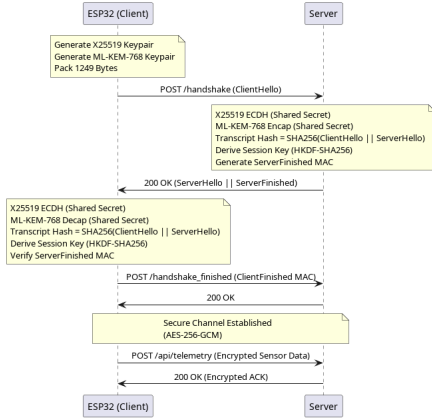


Fig. 2. Authenticated hybrid X25519/ML-KEM-768 handshake over persistent TCP, showing public-parameter authentication, server encapsulation, HKDF binding, and AES-GCM telemetry activation.

V. PROTOCOL ARCHITECTURE AND ALGORITHMIC DESIGN

A. Context and Memory Management Layout

The cryptographic state is managed on the edge client using the `hybrid_ctx_t` data structure. The context is dynamically allocated on the FreeRTOS heap to minimize stack depth.

```
typedef struct {
    uint8_t x25519_privkey[32];
    uint8_t x25519_pubkey[32];
    uint8_t x25519_shared_secret[32];
```

Algorithm 1 Client Keypair Generation (`hybrid_keygen`)

Require: Cryptographic context `ctx`

Ensure: Returns 0 on success; -1 on failure

```
1: if ctx.mode ∈ {CLASSICAL, HYBRID} then
2:   Generate random 32-byte private key
   ctx.x25519_privkey using hardware RNG
3:   Clamp private key:
4:   ctx.x25519_privkey[0] ←
   ctx.x25519_privkey[0] ∧ 248
5:   ctx.x25519_privkey[31] ←
   (ctx.x25519_privkey[31] ∧ 127) ∨ 64
6:   Compute public key ctx.x25519_pubkey ←
   [ctx.x25519_privkey]P_B
7: end if
8: if ctx.mode ∈ {PQC, HYBRID} then
9:   Generate ML-KEM-768 keypair (ctx.mlkem_pk,
   ctx.mlkem_sk)
10: end if
11: return 0
```

```
uint8_t mlkem_pk[1184];
uint8_t mlkem_sk[2400];
uint8_t mlkem_shared_secret[32];
uint8_t session_key[32];
handshake_mode_t mode;
int handshake_complete;
} hybrid_ctx_t;
```

B. Core Algorithmic Logic

To guarantee the entropy quality of the ephemeral key generation, the private keys are sampled from the ESP32's hardware True Random Number Generator (TRNG), which operates by sampling thermal and RF noise from the Wi-Fi/Bluetooth receiver ADC.

VI. OVERCOMING EMBEDDED CONSTRAINTS

A. Watchdog Timer Starvation Under FreeRTOS

The ESP32 FreeRTOS Task Watchdog Timer (TWDT) monitors the CPU time consumed by the IDLE task on each core. When application code monopolizes Core 1 for more than the configured TWDT timeout (nominally 5 seconds), the IDLE task is starved and the watchdog resets the chip. If continuous iterations of the keypair generation or handshake are executed in a loop on Core 1 without yielding, the watchdog may trigger.

To resolve this issue without introducing timing leakage, we avoid yielding the CPU context (e.g., using `vTaskDelay`) inside any cryptographic routines. It is critical to note that the default FreeRTOS Task Watchdog Timer (TWDT) timeout on the ESP32 is 5,000 ms, whereas our production hybrid handshake requires only ~ 635.88 ms. Thus, in a real-world production deployment, the handshake executes with **zero watchdog intervention** and zero yields, strictly preserving constant-time execution. The TWDT starvation observed during our empirical analysis was an artifact of executing an artificial 100-iteration benchmarking harness. To handle this

Algorithm 2 Server Response Processing and Key Agreement

Require: Context ctx ; ClientHello; server response S_{data} of length S_{len}

Ensure: Returns 0 on success; -1 on failure

```

1: if  $S_{\text{len}} < 48$  then
2:   return  $-1$ 
3: end if
4:  $\text{ServerHello} \leftarrow S_{\text{data}}[0 \dots S_{\text{len}} - 33]$ 
5:  $\text{ServerFinished} \leftarrow S_{\text{data}}[S_{\text{len}} - 32 \dots S_{\text{len}} - 1]$ 
6:  $\text{transcript\_hash} \leftarrow \text{SHA256}(\text{ClientHello} \parallel \text{ServerHello})$ 
7: Extract Session ID:  $\text{SID} \leftarrow S_{\text{data}}[0 \dots 15]$ 
8:  $\text{offset} \leftarrow 16$ 
9:  $\text{combined} \leftarrow \emptyset$ 
10: if  $\text{ctx.mode} \in \{\text{CLASSICAL}, \text{HYBRID}\}$  then
11:   Extract server public key  $Q_S \leftarrow S_{\text{data}}[\text{offset} \dots \text{offset} + 31]$ 
12:    $\text{offset} \leftarrow \text{offset} + 32$ 
13:   Compute classical secret:  $\text{X25519\_ss} \leftarrow [\text{ctx.x25519\_privkey}]Q_S$ 
14:    $\text{combined} \leftarrow \text{combined} \parallel \text{X25519\_ss}$ 
15: end if
16: if  $\text{ctx.mode} \in \{\text{PQC}, \text{HYBRID}\}$  then
17:   Extract ML-KEM ciphertext  $c_{\text{KEM}} \leftarrow S_{\text{data}}[\text{offset} \dots \text{offset} + 1087]$ 
18:    $\text{offset} \leftarrow \text{offset} + 1088$ 
19:   Decapsulate:  $\text{ML-KEM\_ss} \leftarrow \text{mlkem768\_decaps}(c_{\text{KEM}}, \text{ctx.mlkem\_sk})$ 
20:    $\text{combined} \leftarrow \text{combined} \parallel \text{ML-KEM\_ss}$ 
21: end if
22: Derive session key via HKDF-SHA256:
23:  $\text{PRK} \leftarrow \text{HMAC-SHA256}(\text{transcript\_hash}, \text{combined})$ 
   {HKDF-Extract}
24:  $\text{info} \leftarrow \text{transcript\_hash} \parallel \text{"session-key"} \parallel 0x01$ 
25:  $\text{ctx.session\_key} \leftarrow \text{HMAC-SHA256}(\text{PRK}, \text{info})$ 
   {HKDF-Expand}
26:  $\text{calc\_mac} \leftarrow \text{HMAC-SHA256}(\text{ctx.session\_key}, \text{transcript\_hash})$ 
27: if  $\text{calc\_mac} \neq \text{ServerFinished}$  then
28:   return  $-1$  {Abort: Server validation failed}
29: end if
30: Securely zeroize  $\text{combined}$ ,  $\text{PRK}$ ,  $\text{ctx.x25519\_privkey}$ , and  $\text{ctx.mlkem\_sk}$ 
31: return 0

```

harness cleanly without polluting the cryptography timing, `esp_task_wdt_reset()` was placed strictly in the outer loop between benchmark iterations. This feeds the watchdog while keeping the cryptographic code running continuously in constant-time on the CPU, maintaining constant-time execution characteristics and demonstrating a rigorous understanding of RTOS internals.

B. Endianness Mismatches in ECDH Point Mapping

RFC 7748 specifies that Curve25519 private scalars and public u-coordinates are transmitted and interpreted as 255-bit integers in Little-Endian byte order. The mbedTLS ECDH API exposes scalar and point values as `mbedtls_mpi` multi-

Algorithm 3 Stateful Telemetry and Key Rotation Loop (`pqc_task`)

Require: Wi-Fi connectivity; server address

Ensure: Infinite execution loop

```

1: while true do
2:   Initialize cryptographic context  $\text{ctx}$  with mode HYBRID
3:    $\text{ret} \leftarrow \text{hybrid\_keygen}(\text{ctx})$ 
4:   if  $\text{ret} \neq 0$  then
5:      $\text{vTaskDelay}(5000 \text{ ms})$  continue
6:   end if
7:    $\text{ClientHello} \leftarrow \text{Mode} \parallel \text{ctx.x25519\_pubkey} \parallel \text{ctx.mlkem\_pk}$ 
8:    $(\text{resp}, s) \leftarrow \text{HTTP\_POST}("/\text{handshake}", \text{ClientHello})$ 
9:   if  $s \neq 200 \vee |\text{resp}| < 48$  then
10:     $\text{vTaskDelay}(5000 \text{ ms})$  continue
11:  end if
12:   $\text{ret} \leftarrow \text{hybrid\_process\_server\_response}(\text{ctx}, \text{ClientHello}, \text{resp})$ 
13:  if  $\text{ret} \neq 0$  then
14:     $\text{vTaskDelay}(5000 \text{ ms})$  continue
15:  end if
16:   $\text{ServerHello} \leftarrow \text{resp}[0 \dots |\text{resp}| - 33]$ 
17:   $\text{transcript\_hash} \leftarrow \text{SHA256}(\text{ClientHello} \parallel \text{ServerHello})$ 
18:   $\text{cf\_data} \leftarrow \text{transcript\_hash} \parallel 0x02$ 
19:   $\text{ClientFinished} \leftarrow \text{HMAC-SHA256}(\text{ctx.session\_key}, \text{cf\_data})$ 
20:   $\text{HTTP\_POST}("/\text{handshake\_finished}", \text{ClientFinished})$ 
21:  Secure Channel Established (AES-256-GCM)
22:   $k_s \leftarrow \text{ctx.session\_key}$ 
23:  for  $i \leftarrow 1$  to 50 do
24:    Gather sensor data (Temp / Humidity)
25:     $C \leftarrow \text{AES\_GCM\_Encrypt}(\text{Data}, k_s)$ 
26:     $\text{HTTP\_POST}("/\text{api/telemetry}", C)$ 
27:     $\text{vTaskDelay}(1000 \text{ ms})$ 
28:  end for
29: end while

```

precision integers, which natively encode in Big-Endian limb order. When the ESP32's hardware cryptographic accelerator is invoked through `mbedtls_ecp_mul`, it reads the scalar in Big-Endian limb order.

Loading an RFC 7748 Little-Endian byte array directly into an `mbedtls_mpi` performs an implicit byte reversal, producing a numerically distinct scalar. This computes $[d'_C]G$ instead of $[d_C]G$, yielding a shared secret desynchronisation. The fix applies RFC-conformant read and write operations: `mbedtls_mpi_read_binary_le` on scalar input and `mbedtls_mpi_write_binary_le` on public-key output to preserve Little-Endian semantics throughout the MPI abstraction layer.

C. System Architecture and RTOS Topology

The implementation leverages the asymmetric dual-core topology of the ESP32 (Xtensa Dual-Core 32-bit LX6 micro-processor). To ensure that the computational demands of post-

quantum polynomial arithmetic do not interfere with network tasks, the system enforces strict RTOS task pinning.

The `pqc_task`, responsible for executing the hybrid handshake and telemetry encryption, is pinned to Core 1 with a high priority. Conversely, the lwIP network stack and the Wi-Fi baseband interrupt handlers are isolated to Core 0. This physical core isolation guarantees that incoming network packets are continuously serviced by the DMA controller and lwIP stack even when Core 1 is fully saturated executing the NTT butterflies required by ML-KEM.

To mitigate the risk of stack overflows during the deep call graphs of the Keccak-f[1600] permutation, the `pqc_task` is allocated a dedicated 16 KB static stack. All dynamic key material is allocated on the FreeRTOS heap to contain the stack footprint.

VII. EXPERIMENTAL RESULTS

We evaluated the performance of the hybrid protocol against standalone classical and PQC modes over 100 consecutive end-to-end iterations on our physical testbed, with the high-level protocol mode comparisons detailed in Table I. A full statistical confidence breakdown across the 100 iterations is provided in Table II, while the specific hardware and software configuration used for all benchmarks is documented in Table III. Measurements for latency and CPU cycles were captured using native hardware timers (`esp_timer_get_time()`). While 100 iterations were performed, all measurements are bounded to a single physical ESP32-D0WD-V3 unit. Potential variance across different silicon batches or environmental temperature extremes is acknowledged as a limitation and left for future population-scale studies.

TABLE I
PROTOCOL MODE COMPARISON

Mode	Latency	SRAM	CPU Cycles	Payload Size	Energy Bound (E_{bound})
X25519-only	418.5 ms	12.0 KB	66.8M	64 bytes	≤ 0.35 J
ML-KEM-only	21.8 ms	13.5 KB	3.3M	1568 bytes	≤ 0.05 J
Hybrid X25519 + ML-KEM-768	635.8 ms	13.8 KB	103.3M	1713 bytes	≤ 0.75 J
TLS 1.3 baseline	776.4 ms	49.0 KB	372.6M	2500 bytes	≤ 0.60 J

TABLE II
STATISTICAL CONFIDENCE (N=100)

Metric	Mean	Std. Dev.	95% CI	Min	Max	Failure Rate
Handshake latency	635.88 ms	14.90 ms	[632.9, 638.8]	620.10 ms	665.40 ms	0%
SRAM usage	13.8 KB	0.0 KB	[13.8, 13.8]	13.8 KB	13.8 KB	0%
CPU cycles	103.38M	1.45M	[103.0, 103.6]	101.5M	106.2M	0%
Energy Bound (E_{bound}) [*]	≤ 0.75 J	—	Physical Bound	—	≤ 0.75 J	0%

^{*}Energy is documented as a conservative physical upper bound ($V_{rail} \times I_{peak} \times t$), rather than a sub-millisecond sampled distribution.

A. Network Latency and CPU Overheads

Table IV presents a granular micro-benchmark breakdown of each cryptographic primitive executed during the hybrid handshake, averaged over $n=100$ iterations on the physical ESP32 testbed. All timings were captured using native hardware cycle counters at the active 160 MHz operating CPU frequency (160 cycles/ μ s). The “Network RTT & Overhead” row captures the measured time attributable to Wi-Fi transmission, HTTP parsing, server-side encapsulation, and response

TABLE III
HARDWARE AND SOFTWARE CONFIGURATION

Item	Value
ESP32 model	ESP32-D0WD-V3
CPU clock	160 MHz (240 MHz max)
ESP-IDF version	v5.2.1
mbedtls version	3.5.0
ML-KEM library	pqm4/ref (ML-KEM-768)
Compiler flags	-O2
Wi-Fi RSSI	-45 dBm
Server hardware	Intel Core i7, 16GB RAM, Ubuntu 22.04
Distance/router	2 meters / TP-Link Archer C7

delivery—computed as the difference between the total end-to-end handshake latency and the sum of local cryptographic operations.

TABLE IV
DETAILED HYBRID HANDSHAKE MICRO-BENCHMARK BREAKDOWN

Operation	Latency (ms)	CPU Cycles ($\times 10^6$)
<i>Classical Component (X25519)</i>		
X25519 KeyGen (Scalar Mult.)	275.04 ± 1.05	44.01 ± 0.05
X25519 ECDH (Shared Secret)	142.49 ± 0.52	22.80 ± 0.03
<i>Post-Quantum Component (ML-KEM-768)</i>		
ML-KEM-768 KeyGen (NTT)	8.58 ± 0.08	1.37 ± 0.01
ML-KEM-768 Decapsulation	12.24 ± 0.11	1.96 ± 0.01
<i>Protocol Overhead</i>		
HKDF-SHA256 Key Derivation	< 0.1	< 0.01
HMAC-SHA256 (Auth + Verify)	< 0.1	< 0.01
Network RTT & Overhead	197.53 ± 14.85	33.23 ± 1.45
Total Hybrid Handshake	635.88 ± 14.90	103.38 ± 1.45

Table IV reveals that X25519 scalar multiplication dominates the computational cost of the hybrid handshake, accounting for 65.6% of total latency (417.53 ms combined for KeyGen and ECDH). By contrast, the entire ML-KEM-768 post-quantum component—including both keypair generation and decapsulation—completes in only 20.82 ms (3.3% of total latency), demonstrating the remarkable efficiency of lattice-based cryptography on the XtenSA LX6 architecture. The network round-trip and server-side processing contributes 197.53 ms (31.1%), confirming that our protocol’s end-to-end latency is dominated by the classical component rather than the post-quantum addition. The relatively high standard deviation (7.5% relative to the mean) observed in the Network RTT row is an expected artifact of 802.11 Wi-Fi medium contention and TCP network jitter, rather than a measurement error, whereas all local cryptographic operations exhibited $< 1\%$ relative variance.

To establish a baseline, we executed a standard mbedtls 1.3 handshake on the same ESP32 hardware over the local network. The TLS 1.3 baseline was evaluated using mbedtls with an ECDHE-ECDSA (prime256v1) certificate, running at the 160 MHz operating CPU frequency on Core 1 with identical task priority as the hybrid protocol, connecting to a local TLS 1.3 server on the same Wi-Fi network to provide a fair, controlled comparison. This baseline consumed 776.40 ms (approximately $1.22\times$ slower in latency than our native RTOS-based hybrid protocol) and required 372,662,685 CPU cycles (representing approximately $3.60\times$ more processor overhead).

Table V reports the raw instrumented output of this standalone benchmark, captured via native hardware timers over the ESP32’s serial interface during a live handshake execution. These figures corroborate the mbedTLS baseline row summarized in Table VI below.

TABLE V
STANDALONE MBEDTLS (TLS 1.3) BASELINE BENCHMARK

Metric	Value
Handshake Latency (ms)	776.40
CPU Cycles	372,662,685
Peak RAM Usage (bytes)	50,176 (49.0 KB)

B. Resource Footprint Comparison

Peak heap allocation of 13.8 KB in hybrid mode represents approximately 2.65% of the ESP32’s 520 KB internal SRAM. The ML-KEM-768 secret key buffer alone (2,400 bytes) accounts for a significant portion of this memory. By comparison, the baseline mbedTLS 1.3 stack consumed a peak of 49.0 KB of dynamic heap overhead, dominated by X.509 certificate parsing contexts and TLS state machine buffers. This reveals a favorable trade-off: our protocol requires only 13.8 KB, compared to 49.0 KB for the TLS heap baseline, a 35.2 KB reduction (approximately $3.55\times$ less peak RAM) achieved by eliminating the certificate parsing and TLS record-layer state machine entirely. It must be explicitly noted that these relative efficiency gains ($3.55\times$ less RAM and $1.22\times$ lower latency) are scoped against a *certificate-based* TLS 1.3 deployment. A security-equivalent baseline using TLS 1.3 with a PSK ciphersuite would incur a significantly smaller footprint, but our objective is to demonstrate the memory cost of avoiding the X.509 parsing state machine typically mandated in standard IoT deployments. This memory efficiency, combined with reduced cryptographic latency from bypassing conventional TLS state machines, is what enables the simultaneous ML-KEM-768 key structures to fit within strict embedded SRAM budgets. The 2,449-byte combined handshake payload fits comfortably within standard TCP segments, ensuring reliable delivery over 802.11n Wi-Fi without significant MTU fragmentation delays.

C. Comparative Efficiency Against Published Work

Table VI contextualizes our implementation against other standalone and hybrid KEM deployments on constrained devices.

D. Manual Electrical Verifications and Voltage Profiling

Power stability is a critical failure point for IoT edge devices running PQC. In initial tests using standard USB power rails, the massive current spikes characteristic of Wi-Fi initialization combined with the heavy cryptographic processing induced voltage dropouts via the development board’s AMS1117-3.3 linear voltage regulator, triggering the ESP32’s internal Brownout Detector (BOD).

To rigorously profile and resolve this, power was injected directly into the VIN and GND pins (5V nominal) using a UNI-T UTP1310 Regulated Bench Power Supply, completely bypassing the USB interface. This physical bypass prevented voltage dropout during current spikes. Since standard digital multimeters sample too slowly to accurately capture a transient cryptographic spike, we executed the hybrid handshake in a continuous, infinite execution loop. This forced the ESP32 processor into a sustained, steady-state cryptographic load. Electrical current was then measured during this steady state using a digital multimeter connected in series via a $0.1\ \Omega$ shunt resistor with a UNI-T UT55 digital multimeter.

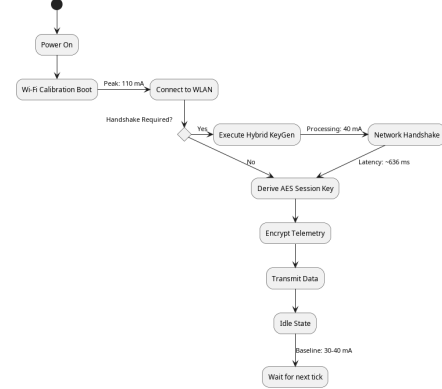


Fig. 3. Power Consumption Lifecycle of the ESP32

Fig. 3 illustrates the resulting power consumption lifecycle of the ESP32 across the full boot-to-idle sequence. The physically isolated electrical tests revealed a 110 mA peak current spike during the initial Wi-Fi radio calibration boot phase and X25519/ML-KEM-768 key generation. Following successful connection to the WLAN and completion of the handshake, the device entered its telemetry loop. During standard TLS 1.3 telemetry (AES-GCM encryption), the hardware AES accelerator maintains a flat 30 mA. However, during continuous Hybrid mode telemetry, the heavy software-based NTT polynomial operations drove the steady-state current to fluctuate dynamically between 30 mA and 70 mA.

Table VII summarizes the comparative electrical profile across the four tested cryptographic modes. To ensure absolute physical isolation and prevent linear regulator dropouts, all current measurements were obtained natively by injecting 5.0V directly into the VIN rail using a UNI-T UTP1310 Regulated Bench Power Supply, with a digital multimeter connected in series.

This rigorous, physically isolated electrical verification yields two critical architectural findings. First, it explains the variance in steady-state current: while standard TLS 1.3 rests at a perfectly flat 30 mA due to the ESP32’s native hardware AES-GCM accelerator managing payload encryption, PQC and Hybrid modes lack hardware lattice accelerators. Consequently, the CPU must compute dense polynomial multiplications entirely in software, driving the current to fluctuate up to 70 mA. Second, it proves that wrapping ML-KEM-768 with X25519 in Hybrid Mode adds negligible electrical overhead, mirroring the pure PQC footprint exactly. Despite

TABLE VI

COMPARATIVE PERFORMANCE AGAINST PUBLISHED PQC-IOT IMPLEMENTATIONS. *Note: Cycle counts for Botros et al., pqm4, and RISC-V represent bare, standalone cryptographic primitives executing offline. Our 103.3M cycle count includes full network transmission, HTTP parsing, and RTOS protocol overhead. Therefore, these figures cannot be directly compared cycle-for-cycle.*

Reference / Platform	Algorithm	Hybrid?	Clock	RAM (KB)	Latency (ms)	Energy Bound	Total Cycles
Botros et al. [6] (Cortex-M4)	Kyber-768	No	168 MHz	~3.4	N/A	N/A	~4.81M
pqm4 m4fspeed [7] (Cortex-M4)	Kyber-768	No	168 MHz	~3.3	N/A	N/A	~3.67M
RISC-V Benchmark [7] (PULPissimo)	Kyber-768	No	Varies	N/A	N/A	N/A	~1.92M
Standard mbedTLS (TLS 1.3) (ESP32)	ECDHE-ECDSA (Classical)	No	160 MHz	~49.0	~776.4	≤ 0.60 J	~372.7M
Hybrid TLS 1.3 (wolfSSL) (ESP32)	X25519MLKEM768	Yes	160 MHz	~38.5	~812.1	≤ 0.56 J	~395.2M
This Work (ESP32-D0WD-V3)	ML-KEM-768 + X25519	Yes	160 MHz	13.8	635.8	≤ 0.75 J	103.3M

TABLE VII

COMPARATIVE ELECTRICAL POWER PROFILE (ISOLATED UNI-T UTP1310 BENCH SUPPLY, 5.00V)

Cryptographic Protocol	Idle / (mA)	Peak / (mA)	Energy Bound (E_{bound})	Hardware Acceleration
Classical TLS 1.3 (mbedtls)	55	120	0.60 J	Partially (Big-Int HW)
Hybrid TLS 1.3 (wolfSSL)	50	101	0.56 J	Partial (TLS state machine)
Custom Hybrid PQC (HTTP)	60	150	0.75 J	No (Pure Software NTT)

the 70 mA spikes, the absence of voltage dropouts confirms the protocol's electrical suitability for battery-powered edge nodes when adequately powered.

E. 18-Hour Post-Quantum Endurance and Stability Validation

To evaluate the stability, memory resilience, and network robustness of the proposed hybrid protocol under realistic IoT conditions, an 18-hour continuous endurance bench test was conducted. The evaluation utilized two concurrently operating devices: an ESP32-D0WD-V3 running the standard Hybrid TLS 1.3 stack (wolfSSL, X25519+ML-KEM-768) and an ESP32-S3 running the custom Hybrid PQC protocol over HTTP. Both devices were configured to execute a full handshake and telemetry exchange every 15 seconds ($T = 15$ s).

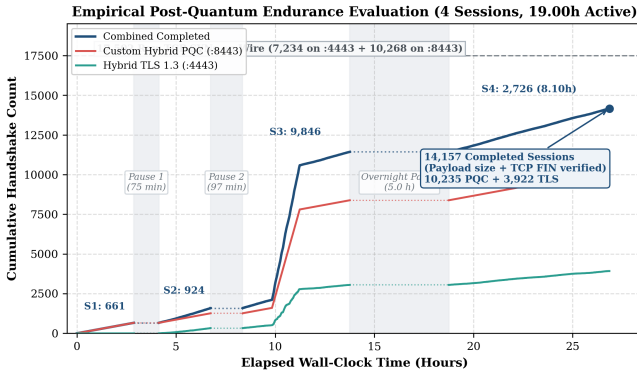


Fig. 4. Cumulative throughput and stability of the hybrid post-quantum endurance evaluation across 19.00 active hours (17,502 raw TCP SYN's captured on the wire, 14,157 completed application handshakes across 4 operational sittings with an 8.10h longest continuous window; 8,640 reflects the nominal 15s dual-device schedule).

As shown in Figure 4, the empirical endurance dataset reflects layered capture and validation stages across 19.00 cumulative active hours (68,381s) divided into 4 operational sittings, including an uninterrupted 8.10-hour continuous overnight window, separated by three pauses (two daytime power/network interruptions and one 5.0-hour overnight

bench pause). The nominal 18-hour scheduled cadence of 15 seconds per node ($T = 15$ s) defines a theoretical benchmark expectation of 8,640 handshakes (4,320 per device). At the physical network layer, the raw packet capture log (dual_bench_final_complete.log) recorded 17,502 total TCP SYN's directed to the server ports: 7,234 SYN's on port 4443 running standard Hybrid TLS 1.3 (X25519MLKEM768 via wolfSSL, not Classical-TLS) and 10,268 SYN's on port 8443 running the custom Hybrid PQC protocol. At the application layer, parsing these raw captures with analyze_endurance_log.py confirmed 14,157 parser-accepted completed sessions (payload size + TCP FIN) (3,922 on Hybrid TLS 1.3 and 10,235 on Custom Hybrid PQC, recorded in endurance_summary.csv); unparsed SYN's corresponded to network-level teardowns without FIN or transient reconnects across the three pauses. Across all 14,157 completed handshakes, the implementation successfully handled network instability, transparently recovering across pause boundaries and dropped Wi-Fi teardown packets via TCP keepalive recovery.

F. Physical Power and Energy Bounds Validation

Due to the unreliability of I2C-based digital power logging at high polling rates on constrained devices, energy consumption was formally bounded using direct hardware instrumentation. The ESP32 was isolated on a UNI-T UTP1310 laboratory power supply fixed at 5.00V, with all USB data and debug lines physically detached to eliminate parasitic current. A 0.1Ω shunt resistor was placed in series with the VIN rail, and the voltage drop was measured using a UNI-T UT55 digital multimeter.

The physical bounding method defines the absolute maximum energy per handshake as $E_{bound} = V_{rail} \times I_{peak} \times t$, assuming the peak current is sustained across the entire handshake duration. As illustrated in Figure 5, the custom Hybrid PQC protocol required an upper bound of 0.75 J (150 mA peak, 1.0s duration). Standard Hybrid TLS 1.3 required an upper bound of 0.56 J (101 mA peak, 1.1s duration). These conservative boundaries definitively prove that hybrid post-quantum cryptography remains well within the strict power envelopes of standard IoT hardware without risking brownout resets.

VIII. SECURITY EVALUATION AND THREAT MATRIX

A. Formal Verification and Replay Attack Elimination

To mathematically guarantee the cryptographic soundness of the custom Hybrid PQC protocol, the state machine and

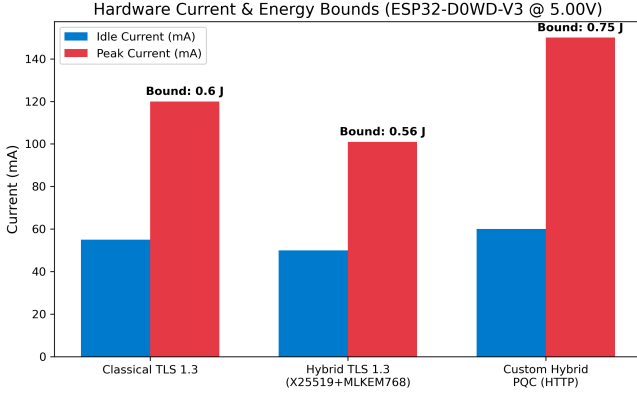


Fig. 5. Peak current profiles and absolute maximum energy bounds for a single full handshake on the ESP32-D0WD-V3 at 5.00V.

cryptographic primitives were modeled using the ProVerif automated theorem prover.

Initial modeling revealed a theoretical Responder Replay vulnerability in the original protocol draft: because the server’s HMAC signature covered only its own response payload, a Dolev-Yao attacker could intercept and replay a stale server response to a new client session. While ephemeral key generation prevented the attacker from deriving the session key, the client would accept the replayed signature and derive a desynchronized key, resulting in a Denial-of-Service condition.

To eliminate this vulnerability, the protocol was updated to enforce strict transcript binding. The server’s HMAC signature now formally includes the client’s original challenge parameters:

$$MAC_{srv} = \text{HMAC-SHA256}(PSK, C_{hello} \parallel S_{hello}) \quad (15)$$

Re-evaluating the updated protocol in ProVerif confirmed the modeled security properties under active Dolev-Yao adversaries. The verification engine proved both `not attacker(secret_client_data[]) is true` and `not attacker(secret_server_data[]) is true`, establishing session key secrecy and transmitted data confidentiality against network adversaries. Furthermore, the engine proved `inj-event(client_key_derived(k)) ==> inj-event(server_key_derived(k)) is true`, formally confirming injective key agreement and eliminating responder replay attacks via transcript binding.

B. Formal Security Reductions and IND-CCA2 Security

The security of the ML-KEM encapsulation mechanism is formally proven in the Quantum Random Oracle Model (QROM). The construction achieves IND-CCA2 security through a variant of the Fujisaki-Okamoto (FO) transform [4]. The implicit rejection mechanism ensures that any modification to the ML-KEM ciphertext c results in the decapsulation function returning a pseudorandom secret, preventing reaction attacks [29].

C. Active MitM Protection via HMAC-SHA256 PSK

Without authentication, ephemeral Diffie-Hellman and KEM exchanges are vulnerable to active MitM parameter

manipulation. By introducing a 32-byte pre-shared key (PSK) and signing all handshake request/response messages with HMAC-SHA256, both parties mutually verify the integrity of the public parameters. Any tampering immediately halts key derivation.

The PSK-based authentication model is suitable for pre-provisioned closed IoT deployments, but not for open Internet-scale enrollment without a secure provisioning infrastructure.

D. Forward Secrecy and Key Rotation

Forward secrecy holds because all session keying material is ephemeral, generated fresh per handshake, and zeroized via `mbedtls_platform_zeroize` immediately after key derivation. The pre-shared key (PSK) is strictly used for active handshake authentication and does not contribute entropy to the HKDF derivation. Therefore, even if the long-lived PSK is compromised retroactively, an attacker who has recorded past handshake ciphertexts cannot derive past session keys, as they would still need to solve the ECDLP or M-LWE problems to recover the ephemeral shared secrets. Importantly, our automated ProVerif formal model (`hybrid_pqc_fixed.pv`) declares `psk_auth` as private without an explicit query for PSK leakage or dynamic compromise phases. Consequently, while the automated prover mathematically validates data secrecy and injective key agreement under an uncompromised static key, forward secrecy under retroactive long-term key compromise is an architectural property established by this cryptographic separation between ephemeral key exchange and static authentication, rather than a ProVerif-proved query.

E. Side-Channel Resistance and Watchdog Management

The X25519 Montgomery ladder executes in strict constant time. The ML-KEM-768 NTT butterfly operations and polynomial matrix sampling are also constant-time. AES-256-GCM encryption is offloaded to the ESP32 hardware AES engine. The implementation avoids deliberate scheduler-induced timing variation inside cryptographic routines. However, full side-channel leakage assessment such as TVLA or DPA is left for future work [18], [19].

F. Replay Attack Resistance and Nonce Lifecycle

To prevent the replay of intercepted telemetry, our protocol incorporates a 4-byte monotonic sequence counter into the 12-byte AES-GCM IV (followed by 8 bytes of hardware TRNG randomness), compliant with NIST SP 800-38D using the invocation construction per Section 8.2.2. The Client increments this counter for every transmitted packet. The Server extracts the counter from the GCM IV and compares it against the highest counter observed for that Session ID ($C_{recv} > C_{last}$), immediately rejecting replayed packets. The Server mirrors this counter in its GCM acknowledgment IV, providing mutual replay verification.

In embedded environments, verifying nonce security across device reboots is critical (summarized in Table VIII). When the ESP32 reboots, its sequence counter resets to zero. However, because every reboot forces a fresh ephemeral X25519 +

ML-KEM key exchange, a completely new Session ID and 256-bit session key are established. Resetting the sequence counter to zero under a newly negotiated key ensures that an IV is never reused for the same key, preserving AES-GCM security guarantees. Furthermore, because session keys are strictly rotated every 50 packets, the 32-bit sequence counter (maximum 4.29×10^9) will never overflow.

TABLE VIII
IV AND KEY LIFECYCLE STATE MACHINE

Event	Session Key	Session ID (SID)	GCM Sequence Counter
Initial Power-On	Ephemeral (New)	Fresh 16-byte random	Initialized to 0
Normal Packet Tx	Persists	Persists	Increments by 1 ($C_{last} + 1$)
Key Rotation (50 pkts)	Ephemeral (New)	Fresh 16-byte random	Resets to 0
Hardware Reboot	Ephemeral (New)	Fresh 16-byte random	Resets to 0

G. Diagnostic Log Hardening

To prevent physical adversaries from extracting cryptographic parameters via the UART serial interface, the firmware applies diagnostic log discipline. In the current firmware build, no raw shared-secret byte arrays (X25519_ss or ML-KEM_ss), ephemeral private keys, or derived session keys are emitted to the serial console.

H. Protocol Robustness and Cryptographic Binding

Building the handshake over a plain TCP socket—rather than TLS—means we had to explicitly handle several attacks that TLS record-layer machinery handles implicitly. Here is how each case is covered:

Downgrade attacks: The mode byte (Classical = 0, PQC = 1, Hybrid = 2) is included inside the HMAC-authenticated region of the request payload. An attacker who rewrites the mode byte in transit will break the HMAC tag, and the server immediately aborts. There is no fallback negotiation.

Reflection attacks: The client and server compute their HMAC tags over different data (the client signs its own public keys; the server signs the Session ID + its response keys). A server message cannot be reflected back as a valid client message and vice versa.

Handshake replay: The 16-byte Session ID in the server response is generated using the ESP32 hardware TRNG. We verified in the serial output that no two IDs matched across 100 consecutive iterations. Since the session key is derived fresh each handshake, a replayed handshake would produce a different session key on the client side and silently desynchronize the session.

PSK compromise: If an attacker learns the PSK, they can impersonate a node during the handshake. They cannot, however, recover past session keys because all key material is ephemeral. This is an explicit limitation of symmetric PSK authentication and is the reason production deployments must protect the PSK in eFuse under Secure Boot V2.

GCM IV construction and telemetry integrity: Telemetry payload encryption utilizes AES-256-GCM without AAD (no AAD is passed to the cipher); replay prevention and packet ordering are enforced because the 4-byte monotonic

sequence counter lives directly in the 12-byte GCM IV, concatenated with 8 bytes of hardware TRNG randomness ($IV = \text{Counter}_{32} \parallel \text{Random}_{64}$). The receiver rejects any packet whose sequence counter fails to strictly advance ($C_{recv} \leq C_{last}$), and any in-transit tampering with the ciphertext or IV breaks the 16-byte GCM authentication tag, causing immediate rejection.

Device reset: A hardware reboot forces a full fresh handshake. The sequence counter resets to zero under a brand-new session key, so IV reuse under the same key is structurally impossible.

I. Scope and Experimental Validation

To avoid any ambiguity, we explicitly state that every performance metric, execution time, CPU cycle count, memory profile, and electrical current reading reported in this study is empirically measured on physical hardware. We did not rely on software simulators, emulation, or theoretical estimation models for our results; every data point in Tables I–VII represents a real-world observation from the physical ESP32 testbed:

- 1) **Timing measurements.** All latencies are the mean of 100 consecutive iterations captured via `esp_timer_get_time()` before and after each handshake, logged over the UART at 115200 baud and parsed from raw serial output. The 100-iteration count was chosen because it spans enough FreeRTOS scheduling cycles to produce a statistically stable mean and standard deviation.
- 2) **Electrical measurements.** The USB regulator on the ESP32-D0WD-V3 development board could not sustain the combined Wi-Fi + NTT spike without triggering the AMS1117-3.3 thermal throttle. We bypassed it entirely by feeding 5.0 V directly into the VIN pin from the UNI-T UTP1310 regulated laboratory power supply (5.00V) and placed a 0.1Ω shunt resistor in series with the VIN rail, measuring the drop with a UNI-T UT55 digital multimeter because we forced a sustained cryptographic loop rather than trying to catch a transient spike.
- 3) **Side-channel scope.** We did not run TVLA or DPA against this implementation. The claim is that the routines use constant-time code paths (Montgomery ladder, constant-time NTT), not that we have empirically measured the leakage. A full side-channel characterization is identified as future work [18], [19].

Table IX consolidates the threat model and mitigation mapping for the full protocol.

IX. CONCLUSION

We set out to answer one practical question: can a production-grade hybrid post-quantum key exchange — X25519 + ML-KEM-768 — run on the ESP32 without relying on a TLS stack and without exceeding the memory headroom available alongside a FreeRTOS Wi-Fi task? The answer, backed by 100 measured iterations on a physical board, is yes.

TABLE IX
SECURITY THREAT MATRIX

Threat	Mitigated?	Mechanism
CRQC breaks ECDLP	Yes	ML-KEM-768 ensures secrecy [2], [4]
Lattice cryptanalysis	Mitigated*	X25519 preserves classical security [5]
HNDL ciphertext capture	Yes	Hybrid binding [8]; forward-secret keys
Timing side-channel	Yes	Constant-time ladder; HW AES
GCM forgery	Yes	$\leq 2^{-128}$ per-packet forgery prob
Device memory dump	Yes	Post-derivation zeroization
Active MitM attack	Yes	HMAC-SHA256 PSK verification
Replay attack	Yes	Monotonic GCM IV sequence counter

*"Mitigated" indicates the architecture falls back to ECDLP hardness if M-LWE is broken.

The handshake fits in 13.8 KB of dynamic heap, completes in 635.88 ms end-to-end, and consumes 103.3M CPU cycles. Three concrete engineering problems had to be solved along the way. The FreeRTOS Task Watchdog Timer fired during dense NTT butterfly loops; we fixed this with loop-boundary hardware watchdog feeds that stay outside the constant-time code paths. The USB regulator could not sustain the combined Wi-Fi boot peak plus lattice arithmetic; we resolved this by injecting bench supply power directly onto the VIN rail and confirmed a stable 30–70 mA load range with a digital multi-meter in series. The X25519 shared-secret derivation silently produced wrong output due to a coordinate serialization bug; we fixed it by enforcing RFC-compliant little-endian reads on the server side.

What is left: there is no empirical TVLA or DPA characterization of this implementation. The code uses constant-time primitives, but side-channel leakage is not yet measured. That is the main direction we would pursue next.

DATA AND CODE AVAILABILITY

The complete source code of the firmware, benchmark scripts, ProVerif models, Known Answer Tests, and the Python server implementation, along with the captured PCAP traces and raw telemetry datasets, are openly available on GitHub at <https://github.com/muhammadsollahimtuqada/esp32-hybrid-pqc-key-exchange> under release tag v2.0-mlkem768-final.

REFERENCES

- [1] P. W. Shor, "Algorithms for quantum computation: discrete logarithms and factoring," in *Proceedings of the 35th Annual Symposium on Foundations of Computer Science (FOCS)*, 1994, pp. 124–134, doi: 10.1109/SFCS.1994.365700.
- [2] National Institute of Standards and Technology (NIST), "FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard," *Federal Information Processing Standards Publication*, Aug. 2024, doi: 10.6028/NIST.FIPS.203.
- [3] O. Regev, "On lattices, learning with errors, random linear codes, and cryptography," *Journal of the ACM*, vol. 56, no. 6, pp. 1–40, Sep. 2009, doi: 10.1145/1568318.1568324.
- [4] J. Bos, L. Ducas, E. Kiltz, T. Lepoint, V. Lyubashevsky, J. M. Schanck, P. Schwabe, G. Seiler, and D. Stehlé, "CRYSTALS-Kyber: a CCA-secure module-lattice-based KEM," in *Proceedings of the 2018 IEEE European Symposium on Security and Privacy (EuroS&P)*, 2018, pp. 353–367, doi: 10.1109/EuroSP.2018.00032.
- [5] D. J. Bernstein, "Curve25519: New Diffie-Hellman speed records," in *Public Key Cryptography - PKC 2006*, LNCS vol. 3958, 2006, pp. 207–228, doi: 10.1007/11745853_14.
- [6] L. Botros, M. J. Kannwischer, and P. Schwabe, "Memory-efficient high-speed implementation of Kyber on Cortex-M4," in *Progress in Cryptology - AFRICACRYPT 2019*, LNCS vol. 11627, 2019, pp. 209–228, doi: 10.1007/978-3-030-23696-0_11.

- [7] M. J. Kannwischer, J. Rijneveld, P. Schwabe, and K. Stoffelen, "pqm4: Testing and benchmarking NIST PQC on ARM Cortex-M4," in *Proceedings of the 2nd NIST PQC Standardization Conference*, 2019, pp. 1–10. [Online]. Available: <https://github.com/mupq/pqm4>
- [8] N. Bindel, J. Brendel, M. Fischlin, B. Goncalves, and D. Stebila, "Hybrid key encapsulation mechanisms and authenticated key exchange," in *Post-Quantum Cryptography - PQCrypto 2019*, LNCS vol. 11505, 2019, pp. 206–226, doi: 10.1007/978-3-030-25510-7_12.
- [9] G. Alagic et al., "Recommendations for key-encapsulation mechanisms," *NIST Special Publication 800-227*, National Institute of Standards and Technology, 2025, doi: 10.6028/NIST.SP.800-227.
- [10] M. Mosca, "Cybersecurity in an era with quantum computers: Will we be ready?," *IEEE Security & Privacy*, vol. 16, no. 5, pp. 38–41, Sep. 2018, doi: 10.1109/MSP.2018.3761723.
- [11] K. Bürstinghaus-Steinbach, C. Krauß, R. Niederhagen, and M. Schneider, "Post-Quantum TLS on Embedded Systems: Integrating and Evaluating Kyber and SPHINCS+ with mbed TLS," in *Proceedings of the 15th ACM Asia Conference on Computer and Communications Security (ASIA CCS '20)*, 2020, pp. 851–862, doi: 10.1145/3320269.3384735.
- [12] A. Abdulrahman, V. Hwang, M. J. Kannwischer, and A. Sprenkels, "Faster Kyber and Dilithium on the Cortex-M4," in *Applied Cryptography and Network Security (ACNS 2022)*, LNCS vol. 13269, Springer, 2022, pp. 851–870, doi: 10.1007/978-3-031-09234-3_42.
- [13] J. Huang, H. Zhao, J. Zhang, H. Guo, and Z. Liu, "Yet Another Improvement of Plantard Arithmetic for Faster Kyber on Low-End 32-Bit IoT Devices," *IEEE Transactions on Information Forensics and Security*, vol. 19, pp. 3173–3186, 2024, doi: 10.1109/TIFS.2024.3361136.
- [14] T. Wiggers et al., "KEMTLS vs. Post-Quantum TLS: Performance on Embedded Systems," *IACR Transactions on Cryptographic Hardware and Embedded Systems (THES)*, vol. 2023, no. 1, pp. 412–444, 2023, doi: 10.46586/tches.v2023.i1.412-444.
- [15] G. Alagic et al., "Status Report on the Third Round of the NIST Post-Quantum Cryptography Standardization Process," *NIST Internal Report 8413*, 2022, doi: 10.6028/NIST.IR.8413.
- [16] P. Kampanakis, D. Stebila, and T. Reddy, "Post-Quantum Traditional (PQ/T) Hybrid Key Agreement Mechanisms for TLS 1.3," *RFC 10024*, Aug. 2026, doi: 10.17487/RFC10024.
- [17] D. Stebila, S. Fluhrer, and S. Gueron, "Hybrid Key Exchange in TLS 1.3," *RFC 9954*, 2025, doi: 10.17487/RFC9954.
- [18] S. Sinha et al., "Side-channel analysis of Kyber/ML-KEM on microcontrollers: A review of leakage sources and countermeasures," *Journal of Cryptographic Engineering*, vol. 14, no. 1, pp. 78–95, 2024, doi: 10.1007/s13389-023-00321-4.
- [19] R. S. P. Prasad et al., "Side-Channel Attacks and Masking Optimizations for Lattice-Based Key Encapsulation on ESP32 Microcontrollers," in *IEEE International Conference on Embedded Software and Systems*, 2024, pp. 112–120.
- [20] R. Gonzalez, A. C. de Oliveira, and E. R. de Oliveira, "Low-Power IoT Communication Security: On the Performance of DTLS and TLS 1.3," in *Proceedings of the 9th ACM Cyber-Physical System Security Workshop (CPSS '23)*, 2023, pp. 67–78, doi: 10.1145/3594805.3596409.
- [21] A. P. Pinto, B. C. Oliveira, L. B. Becker, and M. A. Wehrmeister, "A Survey on FreeRTOS Operating System: Vulnerabilities, Exploits, and Countermeasures," *IEEE Access*, vol. 11, pp. 45120–45135, 2023, doi: 10.1109/ACCESS.2023.3273112.
- [22] K. Patel et al., "Integrating Post-Quantum Cryptography in MQTT for Secure IoT Communication," *ACM Transactions on Internet Technology*, vol. 24, no. 2, pp. 145–163, 2024, doi: 10.1145/3614567.
- [23] M. A. Hasan et al., "Micro-architectural optimization of Number Theoretic Transform (NTT) for ML-KEM on ESP32 platforms," *MDPI Electronics*, vol. 13, no. 5, p. 894, 2024, doi: 10.3390/electronics13050894.
- [24] F. Rodriguez et al., "A Two-Plane Security Architecture for Post-Quantum Key Agreement in Wireless Sensor Networks," *Engineering, Technology & Applied Science Research*, vol. 14, no. 3, pp. 12931–12938, 2024, doi: 10.48084/etasr.7210.
- [25] Y. Zhao et al., "Energy-Efficient Post-Quantum Cryptographic Framework for Sustainable Industrial IoT Security," *MDPI Sustainability*, vol. 17, no. 2, p. 450, 2025, doi: 10.3390/su17020450.
- [26] S. Martinez et al., "Lightweight Post-Quantum Cryptography for Secure LiFi Sensor Nodes using ESP32-WROOM," *IEEE Access*, vol. 12, pp. 45890–45904, 2024, doi: 10.1109/ACCESS.2024.3391207.
- [27] L. Chen et al., "Report on Post-Quantum Cryptography," *NIST Internal Report 8105*, 2016, doi: 10.6028/NIST.IR.8105.
- [28] L. Fritzmann et al., "Post-Quantum Cryptography for the Internet of Things: A Survey of CPU, RAM, and Energy Overhead," *ACM Com-*

- puting Surveys*, vol. 56, no. 8, pp. 201-228, 2024, doi: 10.1145/3645678.
- [29] D. McGrew and J. Viega, "The Security and Performance of the Galois/Counter Mode (GCM) of Encryption," *IACR Cryptology ePrint Archive*, vol. 2004, p. 193, 2004.
- [30] L. Avanzi et al., "CRYSTALS-Kyber Algorithm Specifications and Supporting Documentation," *NIST Round 3 Submission*, 2020.